

Manual 37 — Colombia Data Protection / Habeas Data Controlled Implementation

****Language:**** English

****Controlled baseline:**** Ley Estatutaria 1581 de 2012, applicable provisions consolidated in Decreto 1074 de 2015, and current binding SIC instructions verified 2026-08-31.

****Boundary:**** Constitutional rights, statute, decree, binding SIC instructions, SIC guidance/enforcement, special regimes, contracts, and organization practice remain distinct. This manual is implementation guidance, not legal advice or SIC approval.

Chapter 01 — Purpose, Scope, and Controlled-Source Hierarchy

Use constitutional privacy/habeas-data principles, Ley 1581, applicable decrees, and binding SIC instructions according to their actual legal status. Keep SIC guidance, enforcement facts, special regimes, contracts, and internal procedures separately identified.

Maintain a dated source register, applicability owner, material-change watch, and release-time verification record.

Chapter 02 — Constitutional Habeas Data and Privacy Context

Map the constitutional rights that frame access, updating, rectification, circulation, privacy, and informational self-determination, while distinguishing constitutional principles from the operational duties created by Ley 1581 and sector-specific regimes.

Evidence includes legal-source mapping, policy traceability, rights procedures, and escalation criteria for constitutional or jurisdictional questions.

Chapter 03 — Ley 1581 Applicability, Exclusions, and Jurisdiction Analysis

Document whether each processing activity falls within the general regime, an exclusion, or a special data regime. Do not assume all databases or all organizations are governed identically.

Maintain applicability assessments, facts, exclusions, special-regime overlays, responsible reviewers, and reassessment triggers.

Chapter 04 — Data Categories and Treatment Concepts

Maintain controlled definitions for personal, sensitive, public, private, and semi-private data; processing/treatment; database; data subject; responsible party; processor/encargado; and related concepts. Resolve differences between internal terminology and Colombian legal terminology.

Evidence includes the glossary, classification rules, examples, decisions, and change history.

Chapter 05 — Responsible Party, Processor, and Accountability Roles

Identify the actual responsible/controller and encargado/processor roles based on decisions, instructions, and processing facts rather than labels alone. Define accountability, escalation, data-subject support, security, incidents, and evidence duties.

Maintain role matrices, processor instructions, contracts, owner assignments, and review records.

Chapter 06 — Governance Model, Policies, Privacy Function, and Management Oversight

Establish approved privacy governance with policy ownership, responsible functions, executive oversight, issue escalation, assurance, and periodic management review. Integrate privacy with security, legal, procurement, HR, product, data, operations, and risk.

Evidence includes policies, RACI matrices, committee records, training, dashboards, issues, and corrective actions.

Chapter 07 — Data Inventory, Processing Register, and Information Flows

Maintain an inventory of databases, systems, purposes, data categories, sensitive data, data subjects, sources, recipients, encargados, locations, transfers/transmissions, retention, security, and accountable owners.

Update inventories when business, technology, purpose, vendor, data-flow, or legal conditions change.

Chapter 08 — Authorization/Consent and Documented Exceptions

Where authorization is required, collect and preserve valid evidence of informed authorization for defined purposes. Where an exception applies, document the legal rationale and facts rather than fabricating consent evidence.

Maintain authorization language/version, timestamp, collection method, purpose, withdrawal/revocation handling, exception rationale, and downstream effects.

Chapter 09 — Privacy Notices and Information Duties

Provide notices and privacy policies consistent with actual processing, authorization mechanisms, purposes, rights, responsible-party identity, contact channels, sensitive-data treatment, transfers/transmissions, and relevant processing conditions.

Maintain version control, approvals, publication evidence, readability review, and reconciliation to real systems and inventories.

Chapter 10 — Purpose, Necessity, Proportionality, Quality, and Restricted Circulation

Limit treatment and circulation to legitimate, disclosed, and authorized or otherwise legally permitted purposes. Maintain reasonable data quality, proportionality, necessity, confidentiality, and access restrictions throughout the lifecycle.

Evidence includes purpose registers, minimization reviews, quality controls, access reviews, exceptions, and remediation.

Chapter 11 — Sensitive-Data Processing Controls

Treat sensitive data as heightened risk. Document purpose, legal/authorization basis, necessity, transparency, access restriction, security, sharing, retention, and any applicable exceptions.

Maintain sensitive-data inventories, assessments, authorization/exception evidence, access records, security tests, and reviews.

Chapter 12 — Children's and Adolescents' Data Protections

Apply heightened governance to children's and adolescents' data, including superior-interest and fundamental-rights considerations, purpose limitation, transparency, data minimization, security, and legally appropriate authorization or exception analysis.

Evidence includes age/context assessment, notices, authorization analysis, design review, safeguards, complaints, and remediation.

Chapter 13 — Consultations, Claims, Correction, Updating, Deletion, and Revocation

Operate documented procedures for consultations and claims and for correction, updating, deletion/suppression, and revocation where legally available. Route each request according to the current legal process and the organization's actual role.

Maintain request logs, scope, searches, decisions, responses, escalations, exceptions, and closure evidence.

Chapter 14 — Identity Validation, Representation, Timing, and Evidence

Verify requestor identity and authority proportionately, protect data from unauthorized disclosure, and track applicable response periods and extension conditions. Distinguish statutory timing from voluntary service targets.

Maintain identity/representation evidence, timestamps, correspondence, extensions, response packages, and metrics.

Chapter 15 — Security Safeguards and Administrative/Technical/Physical Controls

Implement safeguards proportionate to data sensitivity, volume, threats, processing context, and business impact. Integrate IAM, secure configuration, encryption where appropriate,

logging, vulnerability management, secure development, physical security, monitoring, resilience, and incident response.

Maintain control mappings, tests, vulnerabilities, exceptions, corrective actions, and risk acceptance.

Chapter 16 — Security Incidents, Escalation, Evidence, and Reporting

Use a documented incident process that determines whether personal data is affected, preserves evidence, assesses scope and harm, triggers internal escalation, and meets current SIC/RNBD reporting obligations where applicable. Do not treat RNBD incident reporting as universal without applicability analysis.

Maintain incident facts, detection time, assessment, decision authority, registry/reporting evidence, communications, remediation, and lessons learned.

Chapter 17 — Privacy Risk and High-Risk Processing Governance

Assess privacy risk for material or high-risk processing such as sensitive data, vulnerable groups, monitoring, profiling, large-scale processing, new technologies, or unexpected secondary use. Apply additional controls and management escalation where risk is elevated.

Maintain methodology, assessments, residual risk, safeguards, approvals, exceptions, and reassessment triggers.

Chapter 18 — RNBD Applicability and Operational Governance

Document whether the organization/databases meet current RNBD registration criteria and maintain registrations/updates only where required. Preserve the current SIC thresholds, categories, update duties, incident-reporting relationships, and any changes in the Circular Única.

Evidence includes applicability analysis, registration records, update logs, incident records, responsible owners, and review dates.

Chapter 19 — International Transfers and Exceptions

For transfers in which the recipient becomes responsible/controller, assess applicable destination-country/adequacy conditions, exceptions, conformity mechanisms, authorization or other legal conditions, and current SIC procedures. Do not treat a declaration of conformity as blanket permission unrelated to facts and scope.

Maintain transfer inventory, destination, recipient role, mechanism/exception, SIC evidence where relevant, approvals, contracts, and reassessment.

Chapter 20 — National/International Transmissions and Processor Contracts

For transmissions to an encargado/processor acting on instructions, maintain contracts or other legally sufficient arrangements defining scope, purpose, security, confidentiality, rights assistance, incidents, subcontracting, deletion/return, and transfer conditions.

Maintain transmission register, agreements, instructions, due diligence, subprocessor records, and monitoring.

Chapter 21 — Vendor, Encargado, Subprocessor, and Third-Party Lifecycle

Risk-assess third parties before use and throughout the relationship. Align role classification, instructions, permitted purposes, security, data-subject support, incident cooperation, location, international flows, retention, audit, and exit controls.

Maintain due diligence, contracts, vendor/encargado register, monitoring, findings, and termination evidence.

Chapter 22 — Cloud, SaaS, Managed Services, and Shared Responsibility

Map cloud data locations, support access, administrators, subprocessors, telemetry, backups, encryption, retention, deletion, security controls, and international transfers/transmissions. Resolve role and cross-border conditions before production use.

Maintain architecture/data-flow maps, configuration evidence, shared-responsibility matrices, contracts, assessments, and exit plans.

Chapter 23 — Marketing, Analytics, Profiling, Monitoring, and Digital Channels

Govern marketing, cookies/trackers, analytics, profiling, personalization, monitoring, and digital-channel processing according to applicable authorization, notice, purpose, necessity, security, and rights rules. Map consumer/e-commerce/sector overlays separately where they apply.

Maintain use-case assessments, authorization/exception basis, notices, configuration evidence, opt-out/revocation handling, and complaints.

Chapter 24 — Workforce and Employment-Data Governance

Apply general privacy duties to employee, applicant, contractor, and workplace data while separately mapping labor, social-security, occupational, and other special obligations. Limit access and monitoring to documented purposes and proportionate controls.

Maintain workforce notices, authorizations/exceptions, access reviews, monitoring assessments, retention rules, investigations, and training.

Chapter 25 — Retention, Archival, Deletion, Suppression, and Disposal

Define retention periods based on purpose, legal obligations, claims, records requirements, contracts, and operational necessity. Implement deletion, suppression/blocking, archival, backup, and secure disposal in accordance with the applicable legal basis and rights outcome.

Maintain schedules, deletion/suppression evidence, archive controls, exceptions, legal holds, and disposal records.

Chapter 26 — SIC Circulars, Instructions, Investigations, Sanctions, and Enforcement Readiness

Maintain an obligation register distinguishing binding SIC instructions/circulars from guidance, concepts, FAQs, enforcement facts, and proposed changes. Prepare a controlled response process for investigations and information requests.

Evidence includes the SIC obligation register, investigation protocol, legal holds, response packages, findings, sanctions/remediation analysis, and corrective actions.

Chapter 27 — Sectoral and Special-Regime Overlay Mapping

Identify financial/credit habeas-data, health, telecom, employment, children, public-sector, consumer, electoral, and other special regimes separately from the general Ley 1581 framework. Resolve which regime governs each dataset/use case before asserting obligations.

Maintain overlay matrices, applicability decisions, citations, owners, conflicts, and change watch.

Chapter 28 — Evidence Architecture, Accountability, and Audit Trail

Create traceability from requirement/source to owner, procedure, system/control, test, exception, remediation, and decision. Protect evidence integrity, access, confidentiality, retention, and version history.

Maintain evidence indexes, control maps, workpapers, logs, approvals, findings, remediation, and provenance.

Chapter 29 — Exceptions, Remediation, Risk Acceptance, and Management Reporting

Require documented exceptions with scope, rationale, compensating controls, owner, approval, residual risk, duration, and expiration. Escalate overdue or material privacy issues to appropriate management and legal/privacy leadership.

Maintain exception registers, corrective actions, risk acceptances, dashboards, escalation, and closure evidence.

Chapter 30 — Legislative Reform, SIC Change Watch, and Reassessment

Monitor enacted changes to Ley 1581/Decreto 1074, SIC Circular Única Title V, RNBD rules, incident requirements, transfer/transmission procedures, binding corporate-rule provisions, sanctions, and material sector overlays. Treat proposals as change-watch only until enacted/effective.

Maintain dated source snapshots, change assessments, implementation plans, effective dates, and candidate-supersession decisions.

Chapter 31 — Exact-Hash Review, Localization, Provenance, and Release Evidence

Freeze controlled source before candidate generation. Bind EN/es-419/pt-BR DOCX/PDF artifacts to exact SHA-256 identities and preserve accessibility, rendered-page, localization, source, workflow-security, and release-QA evidence.

Any material change after freeze requires explicit supersession, regeneration, re-hashing, and re-review of affected gates.

Chapter 32 — Implementation Roadmap, Maturity, and Release-Time Reverification

Implement in phases: applicability/inventory, authorizations/notices, rights, RNBD, security/incidents, transfers/transmissions/vendors, high-risk uses, assurance/evidence, and continual improvement. Measure maturity through evidence-backed outcomes rather than policy completion.

Immediately before publication, reverify Ley 1581/2012, Decreto 1074/2015, current SIC Circular Única Title V, RNBD applicability and incident instructions, transfer/transmission procedures, 2026 conformity processes, binding corporate rules, sanctions/enforcement, and enacted reform. Publication remains sequential after Manual 36 and requires all objective release gates to be green.